

LIFE OS Developer Implementation Book v0.3

Technical Revision

Prepared for Joseph Simpson

Updated May 12, 2026

This document supersedes the technical implementation guidance in `LIFE\_OS\_Developer\_Implementation\_Book\_v0.2.pdf`. Product intent that is not mentioned here remains unchanged. The purpose of this revision is to correct external API assumptions, tighten authentication and security details, and remove ambiguity that could send development down the wrong path.

Global Corrections

1. Discord account linking is **OAuth2 authorization code flow**, not OIDC, for the MVP described here.
2. WordPress remains the authoritative user account. Discord is a linked external account, not the primary identity provider.
3. Request only the Discord scopes actually needed:
 - `identify` for account linking.
 - `guilds.members.read` only if the site must verify that the linked user is already a member of a configured guild.
 - `guilds.join` only if LIFE OS should auto-add the linked user to a configured guild.
4. Do not request Discord `openid` unless the project is explicitly implementing full "Sign in with Discord" identity-token behavior. That is not required for this private WordPress-plus-bot architecture.
5. Alexa implementation must be split into two clearly different options:
 - **MVP / personal-only:** Voice Monkey for spoken Echo announcements.
 - **Future official route:** custom Alexa skill with account linking and, if needed, Proactive Events.
6. Plaid for new development should be designed around:
 - Link token creation on the server.
 - Server-side public token exchange.
 - `/transactions/sync` for transaction updates.
 - `SYNC\_UPDATES\_AVAILABLE` webhooks for incremental refresh flow.
7. Google Calendar should use:
 - initial full sync,
 - persisted `nextSyncToken`,
 - incremental sync,
 - optional push channels with renewal before expiration,
 - fallback polling only as a repair path.

8. Internal LIFE OS bot/bridge endpoints should use a canonical HMAC scheme with timestamp and nonce. Provider callbacks should use the provider's native verification model instead of forcing everything into the same auth pattern.

1.2 MVP Definition - Technical Rows Only

Use the following corrected rows in place of the technical MVP entries from v0.2:

Area	Corrected MVP guidance
---	---
Health data	Inbound signed webhook/import pipeline for steps, sleep, workouts, heart-rate-style metrics, p
Finance	Plaid sandbox/prod flow using server-side Link token creation, server-side token exchange, `/trans
Discord	OAuth2 account linking, slash commands, DM notifications, optional guild membership verification,
Alexa	Voice Monkey spoken announcements for personal MVP if desired. Official Alexa custom skill and Proac

3. System Architecture

3.1 Corrected High-Level Architecture

- WordPress plugin is the system of record for LIFE OS data, admin settings, dashboard rendering, REST endpoints, and custom tables.
- Discord bot is a separate Node.js service responsible for slash commands, DM prompts, and alert delivery.
- Calendar sync, finance sync, health import, and alert dispatch all write canonical records into WordPress tables.
- Alexa delivery is not a single mandatory subsystem:
 - Voice Monkey may be used as a notification provider for private spoken announcements.
 - A custom Alexa skill is a separate future architecture choice, not part of the same MVP by default.

3.2 Corrected Component Responsibilities

Component	Primary responsibility	Recommended location
---	---	---
WordPress plugin	Tables, admin UI, shortcodes, REST API, settings, audit log, timeline rendering	`life-c
Timeline service	Canonical events, interval handling, timestamp window queries	PHP service classes insid
Finance service	Plaid Link token creation, token exchange, cursor storage, transaction sync, recurring sum	
Health ingest service	Signed REST ingestion, validation, normalization, historical backfill	WP REST endp
Calendar sync service	Google OAuth, full sync, sync token storage, push watch renewal, incremental sync	
Discord bot service	OAuth2-linked identity usage, slash commands, DM prompts, bot-to-WP authorization chec	
Notification provider layer	Channel fan-out to Discord and optional Voice Monkey	PHP provider abstractio
Optional Alexa custom skill	Only if official Alexa account-linked skill becomes a deliberate project goal	

3.3 Corrected Job Strategy

- Do not rely on WordPress traffic-based cron alone for private automation.
- Preferred stack:
 - Action Scheduler for queued application jobs.
 - A real server cron or hosting scheduler to trigger WordPress jobs.
 - Discord heartbeat as an extra health check and catch-up signal, not the only scheduler.

3.4 Technology Stack Recommendation - Corrected Notes

Layer	Recommendation	Reason
---	---	---
WordPress	WordPress 6.x, PHP 8.2+, custom plugin, custom DB tables	Good host for admin UI, shortcodes, R
Database	MySQL or MariaDB via `wpdb` migrations	Fits WordPress hosting and backup patterns
Jobs	Action Scheduler plus real cron/scheduler	Better than low-traffic WP-Cron behavior
Discord bot	Node.js with `discord.js`	Strong slash-command and DM ecosystem
Finance	Plaid server-side SDK with cursor-based transaction sync	Matches current Plaid best-practice mod
Calendar	Google OAuth plus incremental sync and renewable watch channels	Avoids wasteful blind polling
Health ingest	Signed JSON/XML/CSV ingestion	Keeps MVP out of native iOS app scope
Secrets	Environment variables plus encrypted DB storage for per-user/provider tokens	Avoid plaintext `wp

5. Data Model Additions and Corrections

The v0.2 table list is directionally good but should add explicit connection and sync-state storage so provider integrations remain maintainable.

5.1 Add `life\_os\_provider\_connections`

Store one row per user/provider connection.

Recommended fields:

- `id`
- `wp\_user\_id`
- `provider` (`discord`, `google\_calendar`, `plaid`, `voice\_monkey`, `health\_bridge`)
- `external\_user\_id`
- `external\_account\_id`
- `scopes\_json`
- `access\_token\_encrypted`
- `refresh\_token\_encrypted`
- `token\_expires\_at`
- `status`

- ``metadata_json``
- ``linked_at``
- ``revoked_at``
- ``last_success_at``
- ``last_error_at``

5.2 Add ``life_os_sync_state``

Store provider-specific cursors, sync tokens, and watch-channel metadata.

Recommended fields:

- ``id``
- ``provider_connection_id``
- ``resource_type``
- ``resource_key``
- ``sync_cursor``
- ``sync_token``
- ``channel_id``
- ``channel_token_hash``
- ``resource_id``
- ``channel_expires_at``
- ``last_sync_started_at``
- ``last_sync_completed_at``
- ``last_webhook_at``
- ``last_error_code``
- ``last_error_message_sanitized``

5.3 Add ``life_os_request_nonces``

Use for replay protection on internal signed endpoints.

Recommended fields:

- ``id``
- ``source_type``
- ``source_id``
- ``nonce``

- `request\_hash`
- `seen\_at`
- `expires\_at`

7. Health Data Module - Corrected Technical Guidance

7.1 MVP Health Source Recommendation

Preferred order:

1. Manual Apple Health XML import for historical backfill.
2. Third-party export app or bridge that can POST structured payloads to LIFE OS.
3. iOS Shortcut bridge where practical.
4. Native HealthKit bridge app later, not MVP.

7.2 Corrected Health Ingest Authentication

Replace the ambiguous `hmac\_sha256(body + timestamp, bridge\_secret)` description with a canonical signing model.

`POST /wp-json/life-os/v1/health/import`

Required headers:

- `X-LifeOS-Bridge-Id: health-export-primary`
- `X-LifeOS-Timestamp: 2026-05-12T15:00:00Z`
- `X-LifeOS-Nonce: uuid`
- `X-LifeOS-Signature: hex(hmac\_sha256(bridge\_secret, timestamp + "." + nonce + "." + raw\_body))`

Server validation rules:

1. Reject if timestamp drift exceeds 5 minutes.
2. Reject reused nonce values.
3. Validate signature against the exact raw request body.
4. Log only sanitized error details, never the secret or full sensitive payload.

7.3 Import Pipeline Corrections

1. Store the raw payload only in a protected table or protected storage area with retention limits.
2. Normalize timestamps to UTC while also preserving the source timezone string.

3. Upsert by provider `source\_id` when available; otherwise use a deterministic hash of source, metric type, value, start, end, and external source metadata.

4. Distinguish between:

- raw samples,
- normalized domain records,
- derived hourly or daily summaries.

5. For large backfills, process in batches to avoid PHP request timeouts and memory spikes.

8. Finance Module - Corrected Technical Guidance

8.1 Plaid Flow

Correct flow for new implementation:

1. WordPress creates a Plaid `link\_token` server-side.
2. Browser opens Plaid Link with that `link\_token`.
3. Browser returns `public\_token` to WordPress.
4. WordPress exchanges `public\_token` server-side for `access\_token`.
5. WordPress stores encrypted token material and Item metadata.
6. Initial transaction bootstrap uses `/transactions/sync`.
7. Incremental updates continue via stored Plaid cursor plus `SYNC\_UPDATES\_AVAILABLE` webhooks.

8.2 Transactions API Recommendation

For new development, use `/transactions/sync` rather than designing around `/transactions/get`.

Required behavior:

- Persist the Plaid cursor for each Item.
- Apply `added`, `modified`, and `removed` transaction changes.
- Preserve `pending\_transaction\_id` relationships so pending-to-posted transitions can be reconciled.
- Mark date-only financial events as lower timestamp precision in the timeline.

8.3 Recurring Transactions

If recurring transaction summaries are included, model them as an optional feature powered by Plaid's recurring transactions add-on via `/transactions/recurring/get`. Do not assume every Plaid deployment will have this add-on enabled on day one.

8.4 Plaid Webhook Verification

Replace the vague `Plaid webhook verification` label with explicit behavior:

- Receive Plaid webhook raw body.
- Read the `Plaid-Verification` header.
- Resolve the signing key through Plaid `/webhook\_verification\_key/get`.
- Validate JWT signature and age.
- Compare the signed request-body hash to the received raw body.

If sandbox work starts before verification is implemented, note that as a temporary dev gap only. Production implementation should verify Plaid webhook authenticity.

8.5 Finance Caveat Corrections

- Balances are not guaranteed real-time unless a real-time balance product or refresh path is intentionally used.
- Car loans may require manual fallback because liabilities coverage depends on institution and supported account type.
- Transaction timing is often date-only; do not misrepresent finance data as exact-time evidence in moment lookup unless the provider supplies time-of-day.

11. Google Calendar Module - Corrected Technical Guidance

11.1 Sync Strategy

Use this exact model:

1. Initial full sync for a bounded historical and future window.
2. Persist `nextSyncToken`.
3. Run incremental sync using the saved sync token.
4. If Google returns `410 Gone`, wipe the cached event state for that watched calendar and run a fresh full sync.
5. Optional push notifications should only trigger a follow-up incremental sync; the push request itself does not carry event details.

11.2 Push Channel Requirements

If push notifications are enabled:

- Use an HTTPS receiver URL.
- Create a unique watch channel per watched calendar/resource.
- Store `channel\_id`, `resource\_id`, optional channel token, and expiration.

- Renew channels before they expire.
- Verify inbound notifications against stored `channel\_id`, `resource\_id`, and channel token if used.

11.3 Fallback Polling

Use fallback polling only for repair or low-volume catch-up. The old 4-minute blind poll assumption should not be the main design.

12. Discord Bot and Identity - Replacement Section

Discord is the command, prompt, and DM alert layer. It must not depend on hard-coded user snowflakes in source code or configuration for normal authorization.

12.1 Correct Identity Model

- WordPress user is primary.
- Discord account is a linked external account.
- The link is created with a standard OAuth2 authorization code flow.
- This is **not** an OIDC requirement for MVP.

12.2 Recommended OAuth2 Scopes

Minimum recommended scope:

- `identify`

Optional scopes:

- `guilds.members.read` if the system must confirm membership in a configured guild through the user token.
- `guilds.join` only if the system should automatically add the user to a configured guild.

Do not request broader scopes unless there is a concrete feature that needs them.

12.3 Corrected Account Linking Flow

1. User visits WordPress and selects **Connect Discord**.
2. WordPress creates a short-lived `state` record bound to the logged-in WP session and intended redirect URI.
3. WordPress redirects to Discord OAuth2 authorization URL.
4. Discord returns an authorization `code` to the registered callback.
5. WordPress validates `state` before token exchange.
6. WordPress exchanges the code server-side and fetches the current user profile from Discord.

7. WordPress stores:

- `discord\_user\_id`
- username/display-name snapshot
- linked scopes
- token expiry
- refresh token only if a later user-token operation truly needs it

8. If membership verification is required:

- use `guilds.members.read` to confirm the linked user's membership in the configured guild, or
- query guild membership through the bot if the design prefers bot-side verification

9. If auto-join is required and `guilds.join` was granted:

- add the user to the configured guild using the same application
- remember that membership screening can leave the member in a `pending` state

10. Show success in WordPress and allow an explicit **Send Test DM** action.

12.4 Corrected Heartbeat Endpoint

`POST /wp-json/life-os/v1/heartbeat`

Required headers:

- `X-LifeOS-Bot-Id`
- `X-LifeOS-Timestamp`
- `X-LifeOS-Nonce`
- `X-LifeOS-Signature: hex(hmac\_sha256(bot\_secret, timestamp + "." + nonce + "." + raw\_body))`

Body example:

```
{
  "source": "discord_bot",
  "bot_version": "1.0.0",
  "heartbeat_id": "uuid",
  "now_utc": "2026-05-12T15:15:00Z"
}
```

Server actions:

1. Verify signature, timestamp, and nonce.
2. Reject duplicate `heartbeat\_id`.
3. Trigger only safe due-job processing.
4. Return counts plus degraded-state warnings if a provider sync is stale.

12.5 Command Authorization

- Slash-command identity comes from Discord interactions.
- Authorization in LIFE OS should map the Discord user ID to the linked WordPress user record.
- The bot should not independently decide owner access from a hard-coded ID list.
- DM flows are acceptable for a single-owner private system, but should still check the mapping table before returning sensitive data.

13. Alexa Integration - Replacement Section

Alexa should be treated as a secondary delivery surface. The project must pick one path at MVP time instead of blending them.

13.1 Option A - Personal MVP via Voice Monkey

Use this when the goal is private spoken announcements on Echo devices without building an official Alexa skill.

Guidance:

- Voice Monkey is a third-party Alexa skill and API.
- This route is appropriate for a private personal build.
- It is not the same thing as Alexa Proactive Events.
- It should sit behind the LIFE OS notification provider interface as an optional channel.

Behavior:

- LIFE OS sends Discord first.
- LIFE OS sends a shortened privacy-safe `alexa\_message` to Voice Monkey if the alert is eligible.
- Failure in Voice Monkey never blocks alert logging, task-state changes, or Discord delivery.

13.2 Option B - Official Alexa Custom Skill

Use this only if the project intentionally wants:

- an official Alexa account-linked skill,
- user-invoked voice experiences,
- or Amazon-native notification semantics.

Important limits:

- Proactive Events are available to custom skills only.

- Proactive Events are factual notification events, not arbitrary always-on freeform speech.
- They require customer permission and skill configuration overhead.
- They carry rate-limit and certification considerations.

13.3 Revised Recommendation

For this private MVP, treat Voice Monkey as the preferred spoken-alert route and treat an official custom Alexa skill as a future expansion path. Do not describe Voice Monkey implementation as if it were fulfilling Proactive Events requirements.

13.4 Voice Monkey Settings - Corrected Guidance

Recommended settings:

- `voice\_monkey\_enabled`
- `voice\_monkey\_api\_token\_encrypted`
- `voice\_monkey\_default\_target`
- `voice\_monkey\_min\_severity`
- `voice\_monkey\_quiet\_hours\_start`
- `voice\_monkey\_quiet\_hours\_end`
- `voice\_monkey\_finance\_privacy\_mode`
- `voice\_monkey\_health\_privacy\_mode`

Do not log raw device identifiers, raw tokens, or full sensitive spoken payloads.

15. REST API Specification - Replacement Section

The REST API should remain under `/wp-json/life-os/v1/`, but auth must be described more precisely.

15.1 Auth Model by Endpoint Type

Endpoint type	Auth model
---	---
Browser/user endpoints	WordPress login session, capability checks, nonces where appropriate
Internal bot/bridge endpoints	Canonical HMAC signature, timestamp window, nonce replay protection
Plaid webhooks	Native Plaid webhook verification model
Google Calendar push receiver	Channel ID/resource ID/token verification
OAuth callbacks	Provider `state` validation plus session-bound link record

15.2 Endpoint Corrections

Endpoint	Method	Auth	Purpose
---	---	---	---
<code>`/timeline/moment`</code>	GET	WP user or signed bot	Moment lookup
<code>`/timeline/range`</code>	GET	WP user	Timeline browser
<code>`/tasks`</code>	GET/POST	WP user or signed bot	List or create tasks
<code>`/tasks/{id}/complete`</code>	POST	WP user or signed bot	Complete task
<code>`/tasks/{id}/snooze`</code>	POST	WP user or signed bot	Snooze task
<code>`/tasks/vault`</code>	GET	Admin only	Resurrection Vault
<code>`/tasks/{id}/restore`</code>	POST	Admin only	Restore decayed task
<code>`/mood`</code>	GET/POST	WP user or signed bot	List or create mood entries
<code>`/health/import`</code>	POST	Signed bridge	Import health data
<code>`/finance/plaid/link-token`</code>	POST	WP user	Create Plaid Link token
<code>`/finance/plaid/exchange`</code>	POST	WP user	Exchange Plaid public token
<code>`/finance/plaid/webhook`</code>	POST	Plaid verification	Receive Plaid webhook
<code>`/calendar/google/callback`</code>	GET	OAuth state	Google OAuth callback
<code>`/calendar/google/push`</code>	POST	Google channel verification	Receive push notification and queue sync
<code>`/discord/oauth/callback`</code>	GET	OAuth state	Discord account linking callback
<code>`/heartbeat`</code>	POST	Signed bot	Catch-up trigger and health ping
<code>`/alerts/test`</code>	POST	Admin only	Send test notification(s)

15.3 Error and Logging Guidance

- Keep the existing consistent JSON error envelope.
- Include a request ID for correlation.
- Never echo provider tokens, secrets, or full upstream payloads in the response body.
- Sanitize external-provider errors before storing them in admin-visible logs.

16. Security, Privacy, and Compliance Posture - Corrected Guidance

16.1 Token Storage

- Encrypt provider tokens before storing them in the database.
- Prefer environment or ``wp-config.php`` secrets for master encryption material.
- Separate long-lived app secrets from per-user provider tokens.
- If a provider token is only needed once for initial linking, do not retain it.

16.2 Replay Protection

Apply replay protection to every internal signed endpoint with:

- timestamp drift enforcement,
- nonce single-use tracking,
- optional request-body hash storage for forensic comparison.

16.3 Provider-Specific Security Notes

- Discord OAuth callback must validate `state`.
- Plaid webhook handling should verify the `Plaid-Verification` header in production.
- Google push receiver should verify channel metadata and renew channels before expiration.
- Voice Monkey credentials should be treated as secrets even though the integration is owner-only.

16.4 Privacy Rules

- Default spoken health and finance messages to vague or silent modes.
- Default Discord details to owner-only DM where possible.
- Never expose sensitive shortcodes publicly.

17. Sync Jobs and Heartbeat - Corrected Guidance

17.1 Required Job Types

Job	Trigger	Purpose
---	---	---
`task_due_scan`	scheduled	Find due and overdue tasks
`task_decay_scan`	scheduled	Move decayed tasks into vault
`mood_prompt_dispatch`	scheduled	Send 4-hour mood prompt
`calendar_incremental_sync`	push-triggered plus scheduled repair	Apply Google Calendar changes
`calendar_watch_renewal`	scheduled	Renew expiring Google watch channels
`plaid_transactions_sync`	webhook-triggered plus scheduled repair	Apply Plaid cursor updates
`plaid_recurring_sync`	scheduled	Refresh recurring summary when enabled
`health_backfill_batch`	queued	Process large import batches
`alert_dispatch`	event-driven	Send Discord and optional Alexa alerts

17.2 Corrected Heartbeat Role

The Discord heartbeat should be treated as:

- a health ping,
- a catch-up trigger,
- and a backup nudge for due jobs.

It should not be the single source of truth for scheduler reliability.

Appendix B - Corrected Developer Notes on External APIs

Provider	Corrected implementation note
---	---
Apple Health	MVP should use import or signed bridge flows, not a native HealthKit app.
Plaid	Use server-side Link token creation and token exchange. New transaction integrations should use <code>/transactions</code>
Google Calendar	Use incremental sync tokens, handle <code>410 Gone</code> , and renew push watch channels before expiration
Discord	Use OAuth2 authorization code flow for account linking. <code>identify</code> is the base scope. <code>guilds.members</code>
Alexa	Voice Monkey is a private third-party spoken-alert path. Proactive Events are a custom-skill-only of
WordPress	Browser endpoints should use WP auth and capability checks. Internal service endpoints should use

Appendix C - Updated Reference Links

- Discord OAuth2 and scopes: <https://docs.discord.com/developers/topics/oauth2>
- Discord OAuth2 and permissions overview: <https://docs.discord.com/developers/platform/oauth2-and-permissions>
- Discord guild member behavior and `guilds.join`: <https://docs.discord.com/developers/resources/guild>
- Discord current-user guild member and `guilds.members.read`:
<https://docs.discord.com/developers/resources/user>
- Google Calendar incremental sync: <https://developers.google.com/workspace/calendar/api/guides/sync>
- Google Calendar push notifications and channel expiration:
<https://developers.google.com/workspace/calendar/api/guides/push>
- Plaid Link overview: <https://plaid.com/docs/link/>
- Plaid Transactions and `/transactions/sync`: <https://plaid.com/docs/transactions/>
- Plaid Transactions API reference: <https://plaid.com/docs/api/products/transactions/>
- Plaid webhook verification: <https://plaid.com/docs/api/webhooks/webhook-verification/>
- Alexa Proactive Events API reference:
<https://www.developer.amazon.com/en-US/docs/alexa/smapiproactive-events-api-reference.html>
- Alexa custom skills overview: <https://developer.amazon.com/alexa/alexa-skills-kit/get-deeper/custom-skills>
- Voice Monkey API v3: <https://voicemonkey.io/docs/api>
- WordPress REST authentication handbook:
<https://developer.wordpress.org/rest-api/using-the-rest-api/authentication/>

Appendix D - Resolved Recommendations

Decision	Recommendation
---	---
Discord identity model	Use OAuth2 account linking to map WP user to Discord user. Do not describe MVP as O
Discord membership handling	Verify membership only if the product truly needs it. Use <code>guilds.join</code> only i

| Plaid transaction model | Use `/transactions/sync` with stored cursor and webhook-driven updates. |
| Calendar sync model | Use sync tokens plus renewable push channels; keep fallback polling as repair logic on
Alexa MVP path	Use Voice Monkey if spoken Echo announcements are desired in the private build.
Official Alexa path	Defer custom skill and Proactive Events unless they become a deliberate V2 goal.
Scheduler reliability	Use Action Scheduler plus real cron; treat Discord heartbeat as backup.

Appendix E - Updated MVP Acceptance Additions

Add the following technical acceptance checks to the v0.2 checklist:

- Discord account linking works through OAuth2 authorization code flow with validated `state`.
- LIFE OS does not request Discord `openid` for the MVP account-linking use case.
- If Discord membership verification is enabled, the linked account can be validated without hard-coded snowflake IDs.
- If Discord auto-join is enabled, the implementation documents the `guilds.join` requirement and handles pending membership-screening state.
- Plaid transaction sync uses `/transactions/sync` and applies `added`, `modified`, and `removed` updates without duplication.
- Plaid webhooks are verified before being trusted in production.
- Google Calendar push watches store expiration metadata and renew before expiry.
- Google Calendar incremental sync handles invalidated sync tokens by performing a clean full resync.
- Internal signed endpoints reject stale timestamps, invalid signatures, and replayed nonces.
- Voice Monkey, if enabled, is clearly documented as a third-party personal-use notification path rather than an official Alexa Proactive Events implementation.